

รายงาน

เรื่อง WordPress บน Microsoft Azure
พร้อมการรักษาความปลอดภัยของเซิร์ฟเวอร์

จัดทำโดย

นายวริทญ์นันษ์	แสงจันทร์	67160057
นายณัฏฐนันท์	สิงห์ทองเมือง	67160064
นายปัณณทัต	เสือหลง	67160074
นายสืบสกุล	พรสว่าง	67160078
นางสาวพัชรพร	ครุธตำคำ	67160099
นายสิรวิชญ์	แซ่กัว	67160108
นายปรมินทร์	ดวงเกิด	67160261

เสนอ

ผศ.ภูสิต กุลเกษม

รายงานฉบับนี้เป็นส่วนหนึ่งของรายวิชา 88633065 Computer Networks

สาขาวิชาวิทยาการคอมพิวเตอร์ คณะวิทยาการสารสนเทศ

มหาวิทยาลัยบูรพา 2569

คำนำ

รายงานฉบับนี้จัดทำขึ้นเพื่อเป็นส่วนหนึ่งของรายวิชา 88633065 Computer Networks สาขาวิชาวิทยาการคอมพิวเตอร์ คณะวิทยาการสารสนเทศ มหาวิทยาลัยบูรพา โดยมีวัตถุประสงค์เพื่อศึกษาและปฏิบัติการติดตั้งระบบจัดการเนื้อหา WordPress บนเครื่องเสมือนของ Microsoft Azure พร้อมกำหนดมาตรการรักษาความปลอดภัยตามโจทย์ 2 ด่าน ได้แก่ ด่านที่ 1 การตั้งค่า DNS, HTTPS และการเสริมความแข็งแรงของ SSH (SSH Hardening) และด่านที่ 2 การติดตั้ง Firewall ให้เชื่อมต่อเข้าเซิร์ฟเวอร์ได้เฉพาะจากประเทศไทย

คณะผู้จัดทำได้ดำเนินงานครอบคลุมตั้งแต่การออกแบบสถาปัตยกรรมระบบ การตั้งค่า SSH ให้ใช้ key เท่านั้น การแก้ปัญหาที่เกิดจากไฟล์ตั้งค่าเริ่มต้นของ Azure การติดตั้ง Firewall ด้วย iptables และ ipset ที่รับเฉพาะ IP ของประเทศไทย ตลอดจนการตรวจความปลอดภัยเพิ่มเติม รวมถึงการแพตช์ช่องโหว่ของ PHP (CVE-2026-109618 และ CVE-2026-109619) และได้รวบรวมหลักฐานการทดสอบจากภายนอกเพื่อยืนยันผลการดำเนินงาน

คณะผู้จัดทำขอขอบพระคุณ ผศ.ภูสิต กุลเกษม อาจารย์ผู้สอนรายวิชา ที่ได้ให้คำแนะนำ ความรู้ และคำเตือนด้านความปลอดภัย จนโครงงานสำเร็จลุล่วง

คณะผู้จัดทำหวังเป็นอย่างยิ่งว่ารายงานฉบับนี้จะเป็นประโยชน์และเป็นแนวทางในการติดตั้งและรักษาความปลอดภัยเว็บเซิร์ฟเวอร์บนระบบคลาวด์ต่อไป หากมีข้อผิดพลาดประการใด คณะผู้จัดทำขออภัยมา ณ ที่นี้ด้วย

คณะผู้จัดทำ

สารบัญ

เรื่อง	หน้า
คำนำ	ก
สารบัญ	ข
สารบัญภาพ	ง
สารบัญตาราง	จ
บทที่ 1 บทนำ	1
1.1. ที่มาและความสำคัญ	1
1.2. โจทย์และวัตถุประสงค์	1
1.3. ขอบเขตและเครื่องมือ	2
บทที่ 2 สถาปัตยกรรมระบบ	3
2.1. ภาพรวมสถาปัตยกรรม	3
2.2. ลำดับการเชื่อมต่อ	3
2.3. ส่วนประกอบและเวอร์ชันของโปรแกรม	4
บทที่ 3 ด่านที่ 1: DNS, HTTPS และ SSH Hardening	5
3.1. การตั้งค่า DNS และ HTTPS	5
3.2. ปัญหาที่พบ	5
3.3. ขั้นตอนการแก้ไข	5
3.4. ผลการทดสอบ	5
บทที่ 4 ด่านที่ 2: Firewall อนุญาตเฉพาะประเทศไทย	7
4.1. เครื่องมือที่ใช้	7
4.2. กฎของ Firewall	7
4.3. ผลการทดสอบ	7
บทที่ 5 การเสริมความปลอดภัยเพิ่มเติม	10
5.1. การแพตช์ช่องโหว่ PHP	10
5.2. มาตรการที่ดำเนินการ	10
5.3. ข้อสังเกตเกี่ยวกับ Azure NSG	10
บทที่ 6 สรุปผลและข้อเสนอแนะ	11
6.1. สรุปผลการดำเนินงาน	11
6.2. ข้อจำกัดที่ทราบ	11
6.3. ข้อเสนอแนะและแนวทางแก้ไข	11
บทที่ 7 Stage 2: ปรับปรุงสถาปัตยกรรมด้านความปลอดภัยและประสิทธิภาพ	12

7.1. เป้าหมาย 12
7.2. สถาปัตยกรรมใหม่ 12
7.3. Reverse proxy ด้วย nginx 13
7.4. การต่ออายุใบรับรองแบบ DNS-01 13
7.5. ระบบสแกน log ด้วย AI และ Security Dashboard 13
7.6. วิธีทดสอบ Stage 2 15
7.7. แผนย้อนกลับ 15
เอกสารอ้างอิง 16

สารบัญภาพ

ภาพที่	หน้า
ภาพที่ 2.1 สถาปัตยกรรมระบบ GoodGoose (เวอร์ชันโปรแกรมจากเครื่องจริง)	3
ภาพที่ 2.2 เวอร์ชันโปรแกรมทั้งหมดและ MySQL ที่ฟังเฉพาะ 127.0.0.1	4
ภาพที่ 3.1 ค่า SSH ที่มีผลจริงจากคำสั่ง sshd -T	6
ภาพที่ 3.2 ล็อกอินด้วย root และรหัสผ่านจากภายนอกถูกปฏิเสธ	6
ภาพที่ 4.1 กฎ iptables ที่ใช้งานอยู่	8
ภาพที่ 4.2 เปิดเว็บผ่าน VPN สิงคโปร์ ขึ้น ERR_TIMED_OUT	8
ภาพที่ 4.3 Azure NSG เปิดเฉพาะพอร์ต 22, 80, 443	8
ภาพที่ 4.4 เปิดเว็บจากไทยได้ปกติ	9
ภาพที่ 7.1 สถาปัตยกรรมระบบ GoodGoose หลังปรับปรุงใน Stage 2	12
ภาพที่ 7.2 GoodGoose Security Dashboard (30 ตุลาคม 2569 เวลา 19:33 น.)	14

สารบัญตาราง

ตารางที่ หน้า
ตารางที่ 1 โจทย์ของแต่ละด่านและผลการตรวจ 1
ตารางที่ 2 ส่วนประกอบและเวอร์ชันของโปรแกรมบนเครื่อง GoodGoose 4
ตารางที่ 3 ผลการทดสอบ SSH hardening 6
ตารางที่ 4 เครื่องมือที่ใช้สร้าง Firewall และหน้าที่ 7
ตารางที่ 5 ผลการทดสอบ Firewall เฉพาะประเทศไทย 8
ตารางที่ 6 มาตรการเสริมความปลอดภัยและผลการตรวจ 10
ตารางที่ 7 การตั้งค่า nginx และประโยชน์ที่ได้ 13
ตารางที่ 8 วิธีทดสอบ Stage 2 และผลที่ต้องได้ 15

บทที่ 1
บทนำ

1.1. ที่มาและความสำคัญ

เซิร์ฟเวอร์ที่เปิดให้บริการผ่านอินเทอร์เน็ตมีความเสี่ยงต่อการถูกโจมตีอยู่ตลอดเวลา ทั้งการเดารหัสผ่านเพื่อเข้าสู่ระบบ SSH และการใช้ช่องโหว่ของซอฟต์แวร์ที่ติดตั้งบนเครื่อง ผู้ดูแลระบบจึงต้องตั้งค่าความปลอดภัยตั้งแต่เริ่มติดตั้ง ไม่ใช่เพียงทำให้เว็บไซต์เปิดใช้งานได้

โครงงานนี้เป็นการติดตั้งระบบจัดการเนื้อหา WordPress บนเครื่องเสมือน (Virtual Machine) ของ Microsoft Azure และเปิดให้บริการผ่านโดเมน DuckDNS โดยโจทย์กำหนดให้ผ่านการตรวจ 2 ด่าน ด่านที่ 1 ตรวจการตั้งค่า SSH และการเชื่อมต่อผ่านโดเมน ส่วนด่านที่ 2 ตรวจ Firewall ที่อนุญาตเฉพาะการเชื่อมต่อจากประเทศไทย นอกจากนี้ คณะผู้จัดทำได้ตรวจความปลอดภัยเพิ่มเติมตามคำเตือนของอาจารย์ผู้สอน โดยเฉพาะช่องโหว่ของ PHP ที่ประกาศเมื่อวันที่ 21 ตุลาคม 2569

1.2. โจทย์และวัตถุประสงค์

โจทย์ที่ต้องผ่านการตรวจมี 2 ด่าน และผลการตรวจของกลุ่มแสดงดังตารางที่ 1

ตารางที่ 1 โจทย์ของแต่ละด่านและผลการตรวจ

ด่าน	โจทย์	ผล
ด่าน 1	เชื่อมต่อผ่าน https://goodgoose.duckdns.org ซึ่งชี้มาที่ VPS, SSH ต้องปิด root ปิด password authentication และใช้ PKI (key) เท่านั้น, แสดงสถาปัตยกรรมพร้อมเวอร์ชันโปรแกรม	ผ่าน
ด่าน 2	ติดตั้ง firewall ให้เชื่อมต่อเข้า server ได้เฉพาะจากประเทศไทย บล็อกประเทศอื่นทั้งหมด	ผ่าน

วัตถุประสงค์ของโครงงานมีดังนี้

- เพื่อติดตั้ง WordPress บน Azure VM และเปิดให้เข้าถึงผ่าน HTTPS ที่โดเมน goodgoose.duckdns.org
- เพื่อตั้งค่า SSH ให้ปิดการล็อกอินด้วย root ปิดรหัสผ่าน และใช้ key (PKI) เท่านั้น (ด่านที่ 1)
- เพื่อติดตั้ง Firewall ให้รับการเชื่อมต่อเฉพาะจากประเทศไทย และบล็อกประเทศอื่นทั้งหมด (ด่านที่ 2)
- เพื่อแสดงสถาปัตยกรรมระบบพร้อมเวอร์ชันของโปรแกรมที่อ่านจากเครื่องจริง

- เพื่อเสริมความปลอดภัยเพิ่มเติม ได้แก่ การแพตช์ช่องโหว่ PHP และการตั้งค่า WordPress, Apache และ PHP ให้รัดกุมขึ้น

1.3. ขอบเขตและเครื่องมือ

- **ขอบเขตด้านระบบ:** ครอบคลุมการติดตั้งเครื่องเสมือนบน Azure (ภูมิภาค Japan East), การตั้งค่า DNS และ HTTPS, การทำ SSH hardening, การติดตั้ง Firewall เฉพาะ IP ประเทศไทย, การเสริมความปลอดภัยของ WordPress, Apache และ PHP ตลอดจนการทดสอบจากภายนอกด้วยเครื่องในประเทศไทยและ VPN จากสิงคโปร์และเนเธอร์แลนด์
- **เครื่องมือที่ใช้ (Tools & Technologies):**
    - Cloud: Microsoft Azure Virtual Machine (Japan East) และ Azure Network Security Group (NSG)
    - DNS: DuckDNS (โดเมน goodgoose.duckdns.org ชี้ไปที่ IP 20.48.47.253)
    - Web Stack: Ubuntu 24.04.5 LTS, Apache 2.4.58, PHP 8.3.6, WordPress 7.1.3 และ MySQL 8.0.46
    - Security: OpenSSH (key แบบ ed25519), iptables, ip6tables, ipset 7.19 และ Let's Encrypt
    - Version Control: GitHub

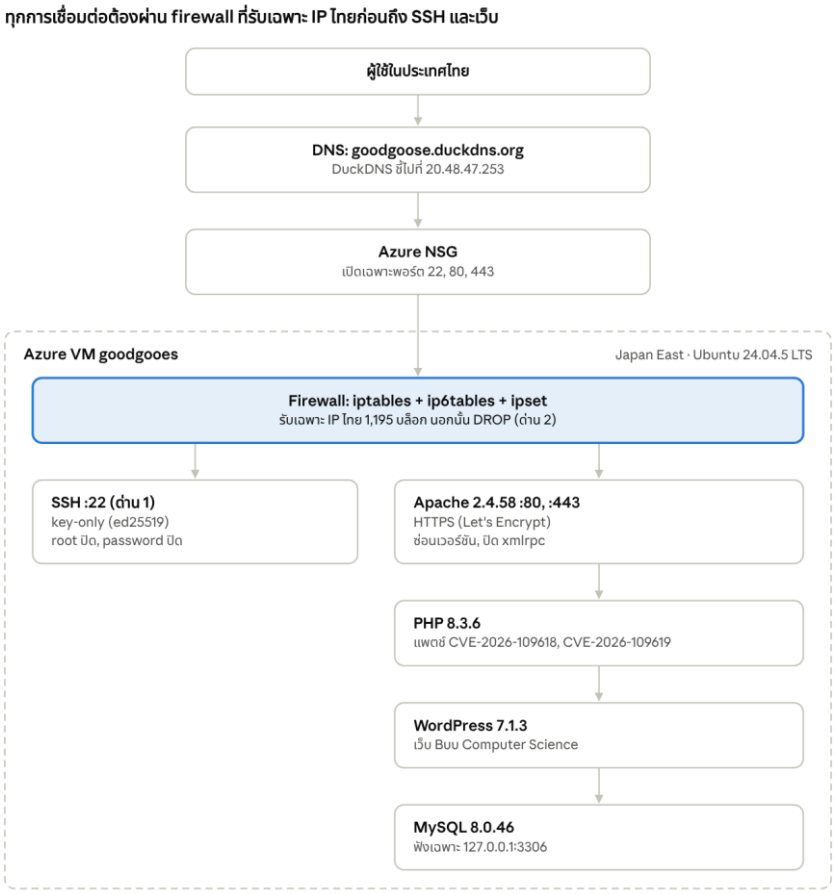
เว็บไซต์และซอร์สโค้ดของโครงงานเข้าถึงได้จากลิงก์ต่อไปนี้

- เว็บไซต์ : https://goodgoose.duckdns.org
- Source code : https://github.com/67160057-lang/GoodGoose

บทที่ 2
สถาปัตยกรรมระบบ

2.1. ภาพรวมสถาปัตยกรรม

ระบบออกแบบให้การเชื่อมต่อทุกครั้งต้องผ่าน DuckDNS, Azure NSG และ Firewall ภายในเครื่องที่รับเฉพาะ IP ของประเทศไทย ก่อนจึงจะถึงบริการ SSH หรือเว็บเซิร์ฟเวอร์ ดังภาพที่ 2.1



ภาพที่ 2.1 สถาปัตยกรรมระบบ GoodGoose (เวอร์ชันโปรแกรมจากเครื่องจริง)

2.2. ลำดับการเชื่อมต่อ

เมื่อผู้ใช้เข้าถึงระบบ การเชื่อมต่อจะผ่านองค์ประกอบตามลำดับดังนี้

1. ผู้ใช้ในประเทศไทยเรียกโดเมน goodgoose.duckdns.org ซึ่ง DuckDNS ชี้ไปที่ IP 20.48.47.253
2. Azure NSG ตรวจพอร์ตและเปิดเฉพาะพอร์ต 22, 80 และ 443 ส่วนพอร์ตอื่นถูก Deny
3. Firewall ในเครื่อง (iptables, ip6tables และ ipset) รับเฉพาะ IP ไทย 1,195 บล็อกนอกนั้นถูก DROP

4. การเชื่อมต่อพอร์ต 22 ไปที่ SSH (key-only, ed25519) ส่วนพอร์ต 80 และ 443 ไปที่ Apache ซึ่งรองรับ HTTPS ด้วย Let's Encrypt
5. Apache ส่งงานให้ PHP 8.3.6 ประมวลผล WordPress 7.1.3 ซึ่งเชื่อมต่อฐานข้อมูล MySQL 8.0.46 ที่ฟังเฉพาะ 127.0.0.1:3306

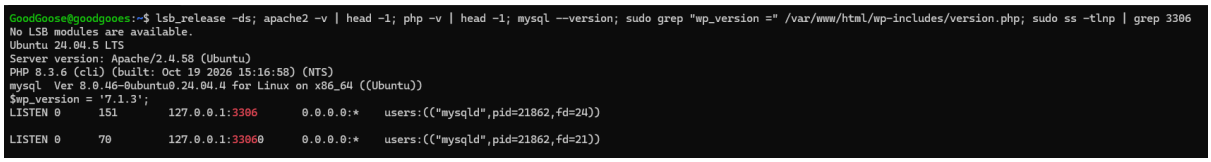
2.3. ส่วนประกอบและเวอร์ชันของโปรแกรม

ส่วนประกอบหลักของระบบและเวอร์ชันที่ใช้แสดงดังตารางที่ 2

ตารางที่ 2 ส่วนประกอบและเวอร์ชันของโปรแกรมบนเครื่อง GoodGoose

ส่วนประกอบ	**เวอร์ชัน**
OS	Ubuntu 24.04.5 LTS
Web server	Apache 2.4.58
PHP	8.3.6 (แพตช์ CVE-2026-109618/109619)
WordPress	7.1.3
Database	MySQL 8.0.46
Firewall	iptables, ip6tables, ipset 7.19

เวอร์ชันทั้งหมดอ่านจากเครื่องจริงเมื่อวันที่ 29 ตุลาคม 2569 ดังภาพที่ 2.2 โดยเว็บเซิร์ฟเวอร์ที่ใช้คือ Apache ไม่ใช่ nginx



ภาพที่ 2.2 เวอร์ชันโปรแกรมทั้งหมดและ MySQL ที่ฟังเฉพาะ 127.0.0.1

บทที่ 3
ด่านที่ 1: DNS, HTTPS และ SSH Hardening

3.1. การตั้งค่า DNS และ HTTPS

โดเมน goodgoose.duckdns.org ชี้มาที่ VM ซึ่งมี IP 20.48.47.253 และเว็บเปิดผ่าน HTTPS ได้ ส่วน SSH รับเฉพาะ key แบบ ed25519 โดยปิดการล็อกอินด้วย root และปิดรหัสผ่าน

3.2. ปัญหาที่พบ

ตอนตรวจครั้งแรก SSH ยังรับรหัสผ่านอยู่ โดยค่าที่มีผลจริงคือ passwordauthentication yes และ permitrootlogin without-password สาเหตุคือ Azure สร้างไฟล์ 50-cloud-init.conf ที่ตั้ง PasswordAuthentication yes ไว้ และ sshd ใช้ค่าจากไฟล์ที่โหลดก่อน จึงทับค่า no ใน 60-cloudimg-settings.conf

3.3. ขั้นตอนการแก้ไข

1. สร้าง key คู่ใหม่บน Windows ด้วยคำสั่ง ssh-keygen -t ed25519
2. ใส่ public key ลงใน /home/GoodGoose/.ssh/authorized_keys ผ่าน Azure Run command และทดสอบว่าล็อกอินด้วย key ได้ก่อนปิดรหัสผ่าน
3. สร้างไฟล์ /etc/ssh/sshd_config.d/00-hardening.conf ให้โหลดก่อนไฟล์อื่น และแก้ 50-cloud-init.conf เป็น no
4. ตรวจไวยากรณ์ด้วย sshd -t แล้วสั่ง systemctl reload ssh

ค่าที่ตั้งในไฟล์ 00-hardening.conf เป็นดังนี้

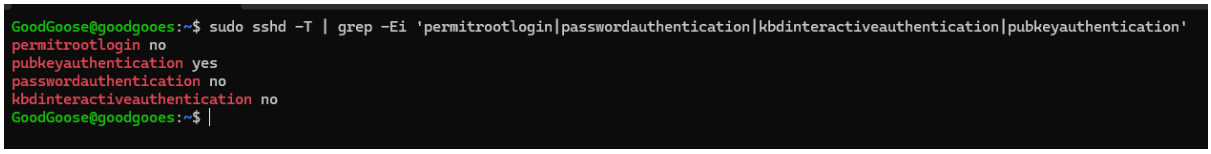
```
PermitRootLogin no
PasswordAuthentication no
KbdInteractiveAuthentication no
PubkeyAuthentication yes
```

3.4. ผลการทดสอบ

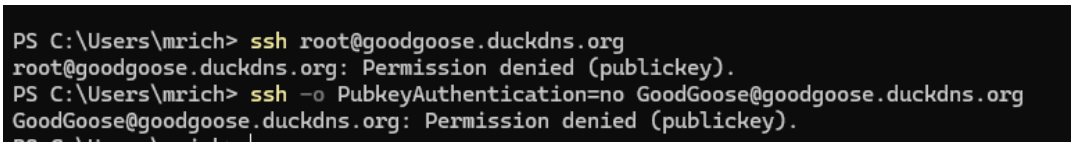
ผลการทดสอบการตั้งค่า SSH แสดงดังตารางที่ 3 และภาพที่ 3.1 ถึง 3.2

ตารางที่ 3 ผลการทดสอบ SSH hardening

การทดสอบ	**ผล**
sshd -T ค่าที่มีผลจริง	root no, password no, kbd-interactive no, pubkey yes
ssh root@goodgoose.duckdns.org จากภายนอก	Permission denied (publickey).
ssh -o PubkeyAuthentication=no GoodGoose@...	Permission denied (publickey). ไม่มีช่องให้พิมพ์รหัสผ่าน
ล็อกอินด้วย key ed25519	เข้าได้ ไม่ถามรหัสผ่าน



ภาพที่ 3.1 ค่า SSH ที่มีผลจริงจากคำสั่ง sshd -T



ภาพที่ 3.2 ล็อกอินด้วย root และรหัสผ่านจากภายนอกถูกปฏิเสธ

จากผลการทดสอบ SSH ปิดการล็อกอินด้วย root ปิดรหัสผ่าน และรับเฉพาะ key เท่านั้น ระบบจึงผ่านด่านที่ 1

บทที่ 4
ด่านที่ 2: Firewall อนุญาตเฉพาะประเทศไทย

4.1. เครื่องมือที่ใช้

Firewall ประกอบด้วยเครื่องมือและบริการต่าง ๆ ตามตารางที่ 4

ตารางที่ 4 เครื่องมือที่ใช้สร้าง Firewall และหน้าที่

เครื่องมือ	หน้าที่
iptables	กรองการเชื่อมต่อ IPv4
ip6tables	ปิดการเชื่อมต่อ IPv6 ทั้งหมด
ipset 7.19	เก็บรายการ IP ไทย 1,195 บล็อก (จาก ipdeny.com) ใน set ชื่อ thai
iptables-persistent / ipset-persistent	บันทึกกฎให้อยู่ต่อหลังรีบูต
Azure NSG	เปิดเฉพาะพอร์ต 22, 80, 443 ส่วนอื่น Deny

4.2. กฎของ Firewall

Firewall ตั้ง policy ของ chain INPUT เป็น DROP และมีกฎเรียงตามลำดับดังนี้

1. รับ loopback
2. รับการเชื่อมต่อที่ตั้งแล้ว (ESTABLISHED, RELATED)
3. รับบริการภายในของ Azure (168.63.129.16)
4. รับ SSH จาก IP ของผู้ดูแล เพื่อกันล็อกตัวเองออกจากเครื่อง
5. รับพอร์ต 22, 80, 443 เฉพาะ IP ที่อยู่ใน set thai
6. รับ ping เฉพาะ IP ไทย

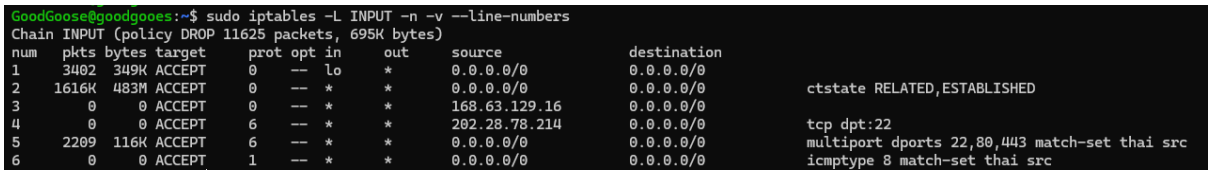
การเชื่อมต่ออื่นนอกจากนี้ถูกทิ้งเงียบ ๆ (DROP) เบราว์เซอร์จากต่างประเทศจึงรอจนหมดเวลา (timeout) ตอนตั้งกฎได้ตั้งตัวย้อนกลับอัตโนมัติ 10 นาทีด้วย systemd-run เผื่อกฎผิดจนเข้าเครื่องไม่ได้ สคริปต์เต็มอยู่ที่ config/firewall/setup-firewall.sh ใน GitHub

4.3. ผลการทดสอบ

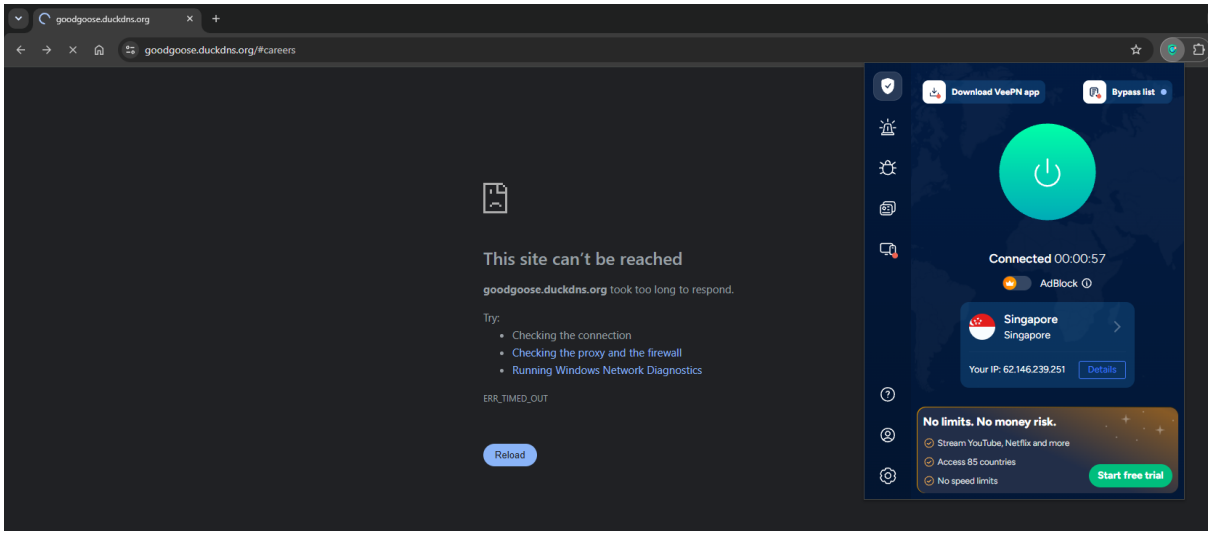
ผลการทดสอบ Firewall แสดงดังตารางที่ 5 และภาพที่ 4.1 ถึง 4.4

ตารางที่ 5 ผลการทดสอบ Firewall เฉพาะประเทศไทย

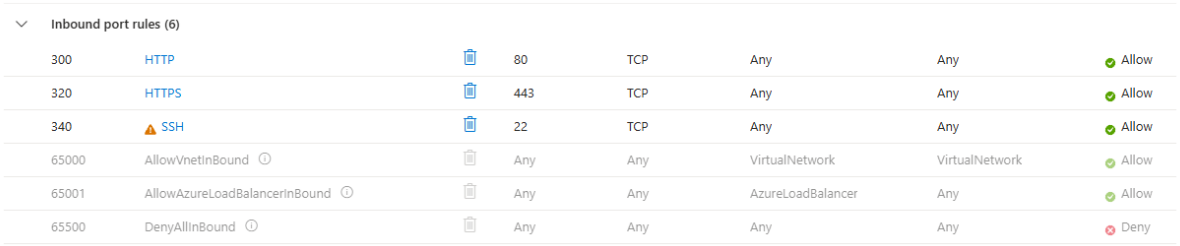
การทดสอบ	**ผล**
เปิดเว็บจากไทย	เข้าได้ปกติ กฎที่ 5 นับได้ 2,209 แพ็กเก็ต
VPN สิงคโปร์ (IP 62.146.239.251)	ERR_TIMED_OUT
VPN เนเธอร์แลนด์ (IP 51.158.254.152)	ERR_TIMED_OUT
iptables -L INPUT -n -v	policy DROP ทิ้งไป 11,625 แพ็กเก็ต
Apache log หลังตั้ง firewall	ไม่พบคำขอจาก IP ต่างประเทศที่ตรวจ



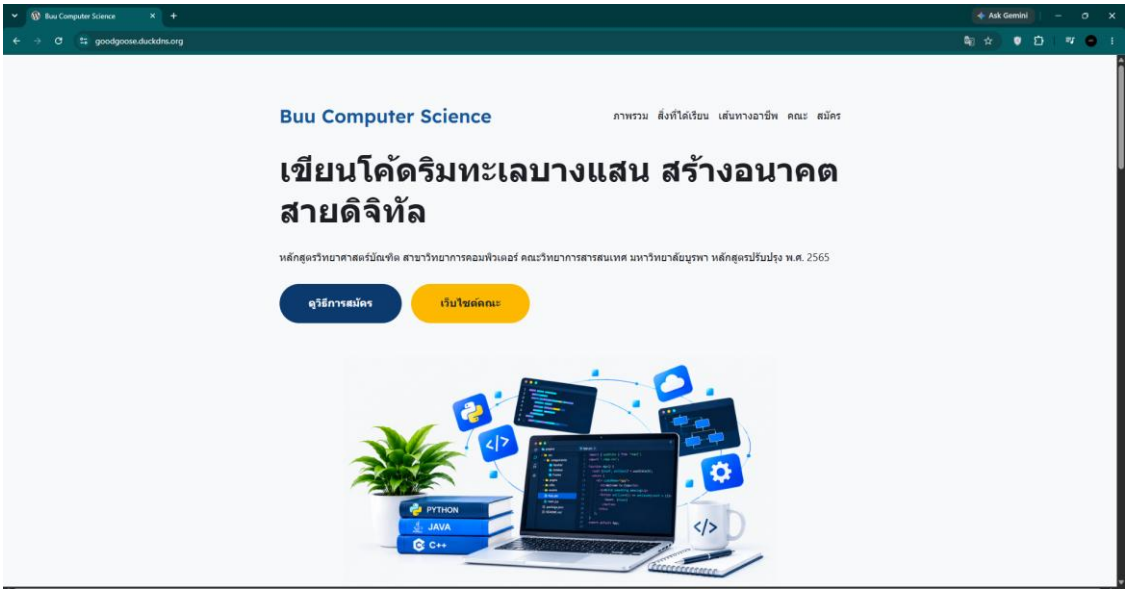
ภาพที่ 4.1 กฎ iptables ที่ใช้งานอยู่



ภาพที่ 4.2 เปิดเว็บผ่าน VPN สิงคโปร์ ขึ้น ERR_TIMED_OUT



ภาพที่ 4.3 Azure NSG เปิดเฉพาะพอร์ต 22, 80, 443



ภาพที่ 4.4 เปิดเว็บจากไทยได้ปกติ

เมื่อเชื่อมต่อจากประเทศไทย เข้าเว็บและ SSH ได้ปกติ ส่วนการเชื่อมต่อผ่าน VPN สิงคโปร์และเนเธอร์แลนด์ขึ้น ERR_TIMED_OUT และ Firewall ทิ้งแพ็กเก็ตจากนอกไทยไปแล้ว 11,625 แพ็กเก็ต ระบบจึงผ่านด่านที่ 2

บทที่ 5
การเสริมความปลอดภัยเพิ่มเติม

5.1. การแพตช์ช่องโหว่ PHP

PHP บนเซิร์ฟเวอร์ได้แพตช์ช่องโหว่ CVE-2026-109618 และ CVE-2026-109619 แล้ว ซึ่งเป็นช่องโหว่ที่ให้ผู้โจมตีรันโค้ดบนเซิร์ฟเวอร์ได้โดยไม่ต้องล็อกอิน (ประกาศเมื่อวันที่ 21 ตุลาคม 2569) Ubuntu แก้ปัญหาด้วยวิธี backport คือนำแพตช์ไปใส่ในแพ็กเกจเดิมโดยไม่เปลี่ยนเลขเวอร์ชัน เลขเวอร์ชันจึงยังเป็น 8.3.6 คณะผู้จัดทำตรวจยืนยันด้วยคำสั่ง apt changelog php8.3-common ซึ่งพบไฟล์แพตช์ CVE-2026-109618_109619.patch

5.2. มาตรการที่ดำเนินการ

มาตรการเสริมความปลอดภัยที่ดำเนินการและผลการตรวจสรุปไว้ในตารางที่ 6

ตารางที่ 6 มาตรการเสริมความปลอดภัยและผลการตรวจ

รายการ	**สิ่งที่ทำ**	**ผลตรวจ**
แพตช์ PHP	apt update && apt upgrade	changelog มี CVE-2026-109618/109619
สิทธิ์ wp-config.php	เปลี่ยนจาก 666 เป็น 640	-rw-r----- www-data
ปิดการแก้โค้ดผ่าน wp-admin	DISALLOW_FILE_EDIT ใน wp-config.php	เพิ่มแล้ว
ซ่อนเวอร์ชัน Apache	ServerTokens Prod, ServerSignature Off	header ขึ้นแค่ Server: Apache
ซ่อนเวอร์ชัน PHP	expose_php = Off	ไม่มี header X-Powered-By
บล็อก PHP ใน uploads, ปิด xmlrpc.php	config Apache wp-hardening.conf	apachectl configtest ผ่าน
ลบไฟล์บอกเวอร์ชัน	ลบ readme.html, license.txt	ลบแล้ว
ฐานข้อมูลไม่เปิดออกภายนอก	MySQL ฟังเฉพาะในเครื่อง	127.0.0.1:3306 (ภาพที่ 2.2)

5.3. ข้อสังเกตเกี่ยวกับ Azure NSG

คำเตือนสีส้มที่กฎ SSH ใน Azure NSG (ภาพที่ 4.3) ขึ้นเพราะพอร์ต 22 เปิดให้ Any เนื่องจาก NSG กรองตามประเทศไม่ได้ กลุ่มจึงคุมด้วย iptables ในเครื่องที่รับเฉพาะ IP ไทย และตั้งให้ SSH รับเฉพาะ key

บทที่ 6
สรุปผลและข้อเสนอแนะ

6.1. สรุปผลการดำเนินงาน

ระบบผ่านทั้ง 2 ด่านตามโจทย์ และมีหลักฐานทั้งจากค่าตั้งในเครื่องและการทดสอบจากภายนอก สรุปได้ดังนี้

- **ด่านที่ 1:** โดเมน goodgoose.duckdns.org ชี้มาที่ VM เว็บเปิดผ่าน HTTPS ได้ และ SSH ปิด root ปิดรหัสผ่าน รับเฉพาะ key แบบ ed25519 โดยแก้ปัญหาไฟล์ 50-cloud-init.conf ที่ทับค่าตั้งเดิมได้สำเร็จ
- **ด่านที่ 2:** Firewall รับเฉพาะ IP ไทย 1,195 บล็อก เชื่อมต่อจากไทยได้ปกติ ส่วน VPN สิงคโปร์และเนเธอร์แลนด์ขึ้น ERR_TIMED_OUT
- **ความปลอดภัยเพิ่มเติม:** แพตช์ช่องโหว่ PHP CVE-2026-109618 และ CVE-2026-109619 ปรับสิทธิ์และค่าตั้งของ WordPress, Apache และ PHP และให้ MySQL ฟังเฉพาะในเครื่อง

6.2. ข้อจำกัดที่ทราบ

- **การต่ออายุใบรับรอง HTTPS:** Let's Encrypt แบบ HTTP-01 ต้องให้เซิร์ฟเวอร์ต่างประเทศเข้าพอร์ต 80 ซึ่ง Firewall บล็อกอยู่ ใบรับรองจะต่ออายุไม่ผ่านในอีกราว 60 วัน
- **รายการ IP ไทยมาจาก ipdeny.com:** IP บางช่วงของผู้ให้บริการไทยอาจไม่อยู่ในรายการ และรายการไม่อัปเดตเอง ต้องรันสคริปต์โหลดใหม่เป็นระยะ
- **VPN ที่ออกอินเทอร์เน็ตจากไทยยังเข้าได้:** Firewall ดูตาม IP ต้นทาง ไม่ได้ดูตัวผู้ใช้

6.3. ข้อเสนอแนะและแนวทางแก้ไข

- **ใบรับรอง HTTPS:** เปิดพอร์ต 80 ชั่วคราวตอนต่ออายุ หรือเปลี่ยนไปใช้การยืนยันแบบ DNS-01 ผ่าน DuckDNS ซึ่งไม่ต้องเปิดพอร์ต 80 ให้ต่างประเทศ
- **รายการ IP ไทย:** ควรตั้งเวลารันสคริปต์โหลดรายการจาก ipdeny.com ใหม่เป็นระยะ และตรวจว่าช่วง IP ของผู้ให้บริการที่ใช้งานอยู่ไม่ตกหล่น
- **การเข้าถึงจาก VPN:** Firewall ตามประเทศไม่สามารถแยกผู้ใช้ที่ออกเน็ตจากไทยได้ จึงควรคงการให้ SSH รับเฉพาะ key เป็นชั้นป้องกันหลักควบคู่กับ Firewall

บทที่ 7
Stage 2: ปรับปรุงสถาปัตยกรรมด้านความปลอดภัยและประสิทธิภาพ

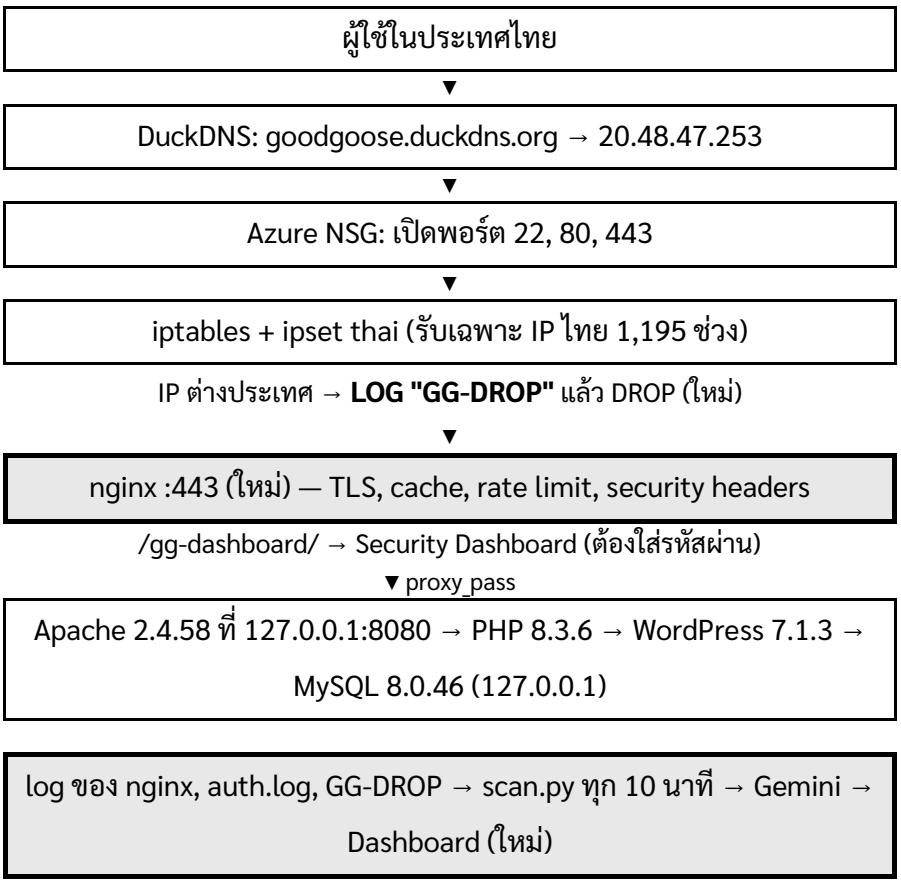
7.1. เป้าหมาย

Stage 2 ปรับโครงสร้างจากบทที่ 2 ให้ปลอดภัยและเร็วขึ้นใน 3 ด้าน ได้แก่ การวาง nginx เป็น reverse proxy หน้า Apache การต่ออายุใบรับรอง HTTPS แบบ DNS-01 ซึ่งแก้ข้อจำกัดในหัวข้อ 6.2 และการใช้ AI สแกน log ทุก 10 นาทีเพื่อแสดงการโจมตีบน dashboard โดยด่านที่ 1 และด่านที่ 2 ยังทำงานครบเหมือนเดิม

กลุ่มเลือกไม่ใช้ Cloudflare เพราะ Cloudflare ต้องย้าย nameserver ของโดเมน แต่ goodgoose.duckdns.org เป็นโดเมนย่อยของ DuckDNS จึงย้ายไม่ได้ และเมื่อผ่าน Cloudflare เซิร์ฟเวอร์จะเห็นเฉพาะ IP ของ Cloudflare ทำให้ Firewall ที่รับเฉพาะ IP ไทยบล็อกผู้ใช้ทุกคน

7.2. สถาปัตยกรรมใหม่

ทุกการเชื่อมต่อยังต้องผ่าน NSG และ Firewall เฉพาะ IP ไทยเหมือนเดิม จากนั้นเข้าสู่ nginx ก่อนถึง Apache ซึ่งเปลี่ยนไปฟังเฉพาะ 127.0.0.1:8080 จึงไม่มีใครเรียก Apache จากภายนอกได้โดยตรง ดังภาพที่ 7.1 กรอบเส้นหนาคือส่วนที่เพิ่มใน Stage 2



ภาพที่ 7.1 สถาปัตยกรรมระบบ GoodGoose หลังปรับปรุงใน Stage 2

7.3. Reverse proxy ด้วย nginx

nginx รับการเชื่อมต่อพอร์ต 80 และ 443 ทั้งหมด พอร์ต 80 ส่งต่อไปที่ HTTPS ส่วนพอร์ต 443 ถอดรหัส TLS แล้วส่งต่อให้ Apache ภายในเครื่อง การตั้งค่าหลักแสดงดังตารางที่ 7

ตารางที่ 7 การตั้งค่า nginx และประโยชน์ที่ได้

การตั้งค่า	ประโยชน์
Apache ย้ายไปฟัง 127.0.0.1:8080 และใช้ mod_remoteip	Apache และ PHP ไม่เปิดออกภายนอก แต่ log ยังเห็น IP จริงของผู้ใช้
proxy_cache (ไม่ cache เมื่อล็อกอิน, /wp-admin, /wp-login.php และคำขอแบบ POST)	หน้าเว็บตอบเร็วขึ้น ตรวจได้จาก header X-Cache-Status: HIT
limit_req ที่ wp-login.php 5 ครั้งต่อนาทีต่อ IP	เกินกำหนดตอบ 429 ป้องกันการสุ่มรหัสผ่านแอดมิน
server_tokens off และ header HSTS, X-Frame-Options, X-Content-Type-Options, Referrer-Policy	ซ่อนเวอร์ชันและเพิ่มการป้องกันฝั่งเบราว์เซอร์
บล็อก xmlrpc.php, ไฟล์ .php ใน uploads, .env และ .git	ตัดคำขออันตรายตั้งแต่ชั้นหน้า ไม่ต้องรอถึง Apache

เมื่อมี proxy อยู่หน้า WordPress ต้องเพิ่มค่าใน wp-config.php ให้ถือว่าเป็น HTTPS เมื่อ header X-Forwarded-Proto เป็น https มิฉะนั้นหน้า wp-admin จะ redirect วนไม่สิ้นสุด

7.4. การต่ออายุใบรับรองแบบ DNS-01

สคริปต์ acme-dns01.sh ใช้ acme.sh โหมด dns_duckdns ยืนยันความเป็นเจ้าของโดเมนผ่าน TXT record ของ DuckDNS แทนการให้ Let's Encrypt เข้ามาที่พอร์ต 80 จึงต่ออายุได้โดยไม่ต้องเปิด Firewall ให้ต่างประเทศ token ของ DuckDNS เก็บในเครื่องที่ root อ่านได้คนเดียว และไม่อยู่ใน GitHub

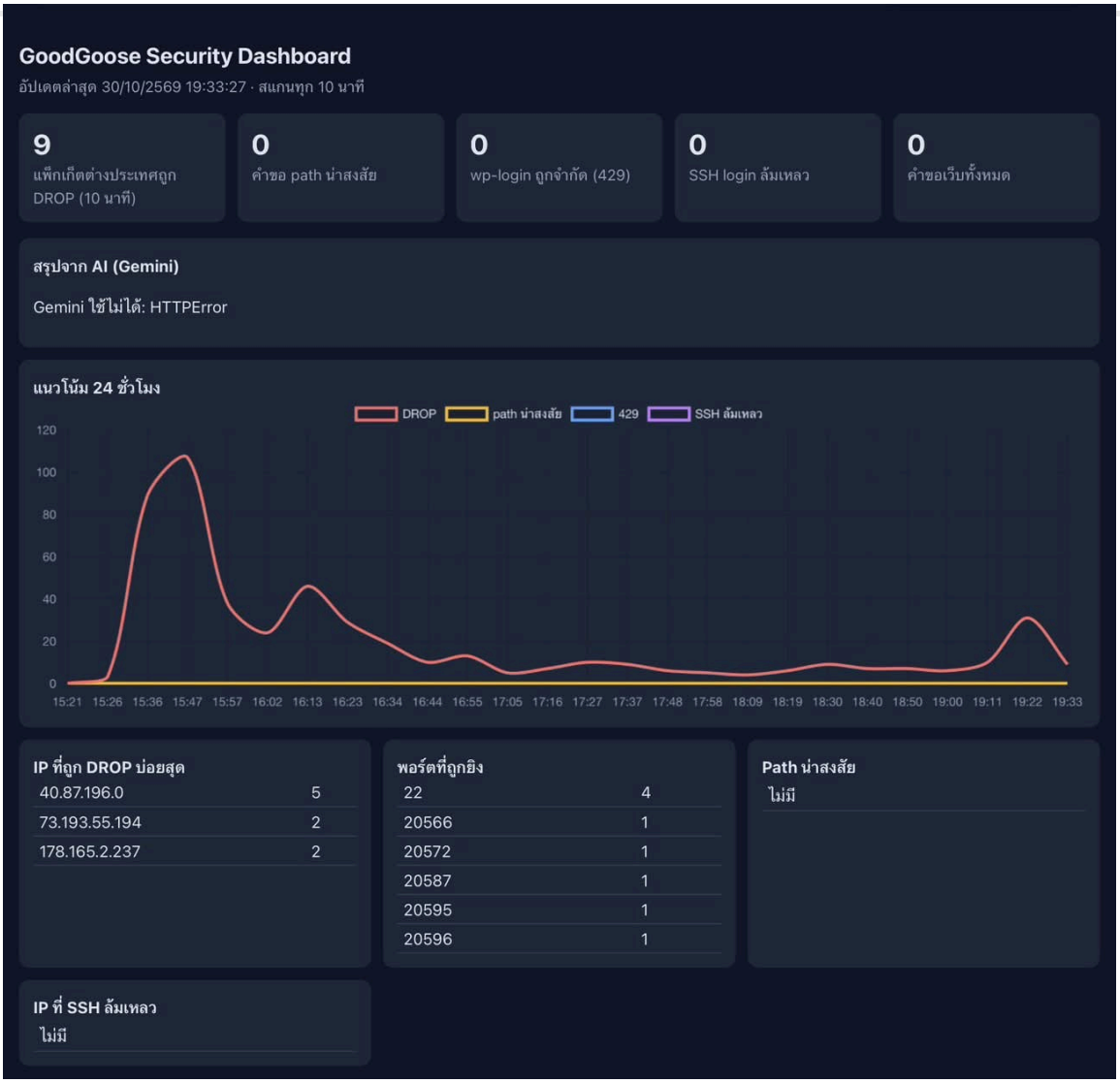
7.5. ระบบสแกน log ด้วย AI และ Security Dashboard

systemd timer เรียกสคริปต์ scan.py ทุก 10 นาที โดยมีขั้นตอนดังนี้

1. อ่านเฉพาะบรรทัดใหม่ของ access log ของ nginx, auth.log และบรรทัด GG-DROP ใน kern.log
2. นับและจัดกลุ่มด้วยกฎ เช่น IP ที่ถูกจำกัด 429, path อันตราย (/wp-login.php, /.env, /phpmyadmin), SSH ที่ล็อกอินไม่สำเร็จ และพอร์ตที่ถูก DROP
3. ส่งเฉพาะสรุปตัวเลขให้ Gemini วิเคราะห์ประเภทการโจมตีและระดับความเสี่ยงเป็น JSON
4. บันทึกผลเป็น latest.json และ history.json ให้หน้า dashboard แสดงผล

หลักการออกแบบมี 4 ข้อ ข้อแรก ตัวเลขทั้งหมดมาจากกฎ AI ทำหน้าที่อธิบายเท่านั้น ถ้า Gemini

ใช้ไม่ได้ dashboard ยังแสดงตัวเลขครบ ข้อสอง ข้อความใน log มาจากผู้โจมตีและอาจแฝงคำสั่งหลอก AI (prompt injection) ระบบจึงไม่ให้ AI สั่งบล็อก IP เอง และหน้า dashboard แสดงข้อความแบบ textContent เพื่อกัน XSS ข้อสาม API key เก็บใน /etc/goodgoose/gemini.env สิทธิ์ 600 ข้อสี่ dashboard ต้องล็อกอินด้วย basic auth



ภาพที่ 7.2 GoodGoose Security Dashboard (30 ตุลาคม 2569 เวลา 19:33 น.)

จากภาพที่ 7.2 ในรอบล่าสุด Firewall ทิ้งแพ็กเก็ตจากต่างประเทศ 9 แพ็กเก็ต กราฟ 24 ชั่วโมงมีจุดสูงสุดราว 107 แพ็กเก็ตต่อ 10 นาทีช่วง 15:47 น. หลังเริ่มเก็บข้อมูล IP ที่ถูก DROP บ่อยที่สุดคือ 40.87.196.0 (5 ครั้ง) ตามด้วย 73.193.55.194 และ 178.165.2.237 (2 ครั้ง) พอร์ตที่ถูกยิงมากที่สุดคือ 22 (SSH) แสดงว่ามีบอตสแกนหา SSH อยู่ตลอด ส่วนพอร์ตสูง 20566–20596 เป็นพอร์ตชั่วคราว ซึ่งมักเป็นแพ็กเก็ตตอบกลับที่มาถึงหลังการเชื่อมต่อปิดไปแล้ว

ตัวเลข path น่าสงสัย, 429 และ SSH ล้มเหลวเป็น 0 เพราะ Firewall ตัดการเชื่อมต่อจากต่างประเทศก่อนถึง nginx และ SSH ส่วนกล่องสรุปจาก AI ในรอบนี้ขึ้น HTTPError

คือเรียก Gemini ไม่สำเร็จ แต่ตัวเลขและกราฟยังแสดงครบ ซึ่งยืนยันหลักการข้อแรกที่แยกการนับออกจาก AI

7.6. วิธีทดสอบ Stage 2

ตารางที่ 8 วิธีทดสอบ Stage 2 และผลที่ต้องได้

ตัววัด	วิธีตรวจ	ผลที่ต้องได้
cache ทำงาน	curl -I หน้าแรก 2 ครั้ง	ครั้งที่ 2 ขึ้น X-Cache-Status: HIT
rate limit	ส่งคำขอ wp-login.php 10 ครั้งติดกัน	ได้ 429 หลังครั้งที่ 4
Apache ไม่เปิดออกภายนอก	ss -tlnp	Apache ฟังเฉพาะ 127.0.0.1:8080
ด่านที่ 1–2 ยังผ่าน	ทดสอบ SSH และ VPN ต่างประเทศซ้ำ	Permission denied (publickey) และ ERR_TIMED_OUT
Dashboard	เปิด /gg-dashboard/	ต้องใส่รหัสผ่าน และข้อมูลอัปเดตทุก 10 นาที

7.7. แผนย้อนกลับ

สคริปต์ install.sh สำรองค่าตั้ง Apache, wp-config.php และกฎ iptables ก่อนแก้ทุกครั้ง หากขั้นใดผิดพลาดจะเรียก rollback.sh อัตโนมัติ ซึ่งหยุด nginx และคืนค่า Apache ให้รับพอร์ต 80 และ 443 เหมือน Stage 1 ได้ภายในไม่ถึง 1 นาที ไฟล์ทั้งหมดอยู่ในโฟลเดอร์ stage2 ของ GitHub ของโครงงาน

เอกสารอ้างอิง

ipdeny.com รายการบล็อก IP ของประเทศไทย (th.zone):
https://www.ipdeny.com/ipblocks/data/countries/th.zone
GoodGoose Source code และสคริปต์ทั้งหมดของโครงงาน:
https://github.com/67160057-lang/GoodGoose
เว็บไซต์โครงงาน GoodGoose: https://goodgoose.duckdns.org
nginx documentation: https://nginx.org/en/docs/
acme.sh (ACME client รองรับ DNS-01 ผ่าน DuckDNS): https://github.com/acmesh-official/acme.sh
Gemini API documentation: https://ai.google.dev/gemini-api/docs